

Mapeo Detallado de Preguntas de la Encuesta a Requisitos Normativos y Marcos de Referencia

Nota: Este mapeo tiene carácter orientativo. No sustituye a la interpretación jurídica ni a la lectura directa de las normas aplicables.

1. Leyenda de marcos y referencias

- NIS2: Directiva (UE) 2022/2555, especialmente:
- Art. 21: Gestión de riesgos de ciberseguridad.
- Art. 23: Notificación de incidentes.
- ENS: Esquema Nacional de Seguridad (España).
- DORA: Reglamento (UE) 2022/2554 sobre resiliencia operativa digital en el sector financiero.
- ISO 27001: Norma UNE-EN ISO/IEC 27001:2022.
- ENISA SOC/CSIRT: Guías de ENISA para configuración y operación de SOC y CSIRT.
- Otros: Buenas prácticas generales e índices de capacidad (NCSI, etc.).

2. Tabla de mapeo

Pregunta encuesta (sección / número)	Tema principal	NIS2	ENS	DORA	ISO 27001 / otros
1.1 Tipo de organización	Contexto / clasificación entidad	Art. 2, 3 (ámbito entidades)	Ámbito subjetivo ENS	Ámbito entidades financieras	Análisis de contexto (cláusula 4)
1.2 Ámbito geográfico	Alcance territorial	Coordinación transfronteriza	–	–	Contexto interno/externo
1.3 Tamaño organización	Escala, criticidad potencial	Proporcionalidad medidas	Proporcionalidad ENS	Proporcionalidad	Dimensionamiento del SGSI
1.4 Rol del encuestado	Gobernanza, responsabilidades	Art. 20 (gobernanza)	Organización de la seguridad	Responsabilidades directivas	A.5 Liderazgo y compromiso
1.5 Modelo de SOC	Capacidad de detección / respuesta	Art. 21 (medidas técnicas)	Operación y explotación	Gestión de incidentes	A.5.23 Gestión de seguridad de la información
2.1 Existencia de SIEM	Capacidades de monitorización	Art. 21(2)	Registro de actividad	Registro y monitorización	A.8.16 Monitorización de seguridad
2.2 Tipo de solución SIEM	Arquitectura tecnológica	Art. 21(2),(5)	Medidas organizativas/técnicas	Requisitos TIC y terceros	Cláusula 6 planificación, A.5.21 nube
2.3 Cobertura de fuentes	Alcance de logging y telemetría	Art. 21(2)	Registro de actividad, protección de comunicaciones	Monitorización continua	A.8.16, A.8.20, A.5.10
2.4 Cobertura activos críticos	Monitorización de activos esenciales	Art. 21(2),(3)	Activos y servicios esenciales	Gestión de activos críticos	A.5.9 inventario, A.5.12 clasificación
2.5 Calidad de datos SIEM	Integridad y consistencia de registros	Art. 21(2)	Integridad y trazabilidad	Integridad de datos	A.5.13, A.8.9 registro de eventos
2.6 Monitorización de identidad	Zero Trust, IAM, detección de abusos de credenciales	Art. 21(2),(3)	Control de acceso	Gestión de acceso y privilegios	A.5.17, A.5.18 control de acceso

3.1.1 Medición MTTD	Velocidad de detección	Art. 21(2), Art. 23(1)	Detección de incidentes	Tiempos de detección	A.8.16 monitorizació n
3.1.2 Cálculo MTTD	Definición formal del KPI	Art. 21(2)	Procedimient os documentados	Medición de desempeño	Cláusula 9 evaluación del desempeño
3.1.3 Objetivos de MTTD	Umbrales y objetivos	Art. 21(2),(3)	Nivel de seguridad requerido	SLA internos	Planificación de objetivos
3.1.4 Medición MTTR	Velocidad de respuesta / recuperación	Art. 21(2),(3)	Gestión de incidentes	Resiliencia operativa	A.5.24 gestión de incidentes
3.1.5 Segregación por tipo incidente	Granularidad de mediciones	Art. 21, 23	Clasificación de incidentes	Tipología de incidentes	A.5.24, A.8.16
3.2.1 Tasa falsos positivos	Calidad de detección	Art. 21(2)	Eficacia de controles	Calidad de alertas	Mejora continua (cláusula 10)
3.2.2 Conversión alerta-incidente	Relevancia de alertas	Art. 21(2)	Dimensionam iento de capacidades	Análisis de eficacia	A.8.16, métricas internas
3.2.3 Alertas descartadas, errores	Control de errores y riesgos residuales	Art. 21(2)	Gestión de riesgos	Gestión de fallos de control	A.6.3 gestión de cambios, A.8.16
3.2.4 Carga por analista	Dimensionam iento SOC, fatiga de alerta	Art. 21(2)	Recursos adecuados	Recursos operativos	A.7.4 recursos humanos
3.3.1 Inventario de activos críticos	Gestión de activos alineada con ENS/NIS2	Art. 21(2),(3)	Inventario de activos	Gestión de activos críticos	A.5.9, A.5.12
3.3.2 Cobertura MITRE ATT&CK	Diseño de casos de uso alineados a amenazas	Art. 21(2)	Análisis de amenazas	Escenarios de riesgo	Mejores prácticas SOC / ENISA
3.3.3 Latencia de ingesta	Monitorizació n casi en tiempo real	Art. 21(2)	Requisitos de detección	Monitorizació n continua	A.8.16
3.3.4 Errores de parsing	Integridad de los registros	Art. 21(2)	Registro y almacenam iento	Integridad y trazabilidad	A.8.9, A.8.16

4.1 Sujeción a NIS2	Clasificación entidad	Art. 2, 3	–	–	Contexto y obligaciones legales
4.2 Uso del SIEM en notificación	Evidencia técnica para reporte	Art. 23	Obligación de registro	Obligaciones de reporte	A.5.24, A.8.16
4.3 KPIs de notificación	Tiempos y calidad de notificación	Art. 23(1)–(4)	ENS: gestión de incidentes	Plazos de notificación	Indicadores de desempeño
4.4 Mapeo casos de uso–controles	Trazabilidad entre controles y monitorización	Art. 21(2)	Medidas de seguridad ENS	Requisitos de control	Anexos A ISO 27001
4.5 Métricas de resiliencia	Conexión con continuidad de negocio	Art. 21(2),(3)	Continuidad ENS	Resiliencia operativa	ISO 22301, A.5.29 continuidad
5.1 Uso de IA/análítica avanzada	Tecnologías de detección	Art. 21(2)	Adecuación de medios	Innovación tecnológica	Mejores prácticas de SOC
5.2 KPIs de IA	Evaluación de modelos avanzados	Art. 21(2)	Efectividad de controles	Evaluación continua	Cláusula 9 evaluación
5.3 Uso de SOAR	Automatización de respuesta	Art. 21(2)	Respuesta a incidentes	Respuesta y recuperación	A.5.24, A.8.16
5.4 Métricas de automatización	Eficiencia operativa del SOC	Art. 21(2)	Eficiencia de controles	Optimización de procesos	Mejora continua (cláusula 10)
5.5 Auto-evaluación de madurez	Nivel global de capacidades	Art. 21(2),(3)	Adecuación del nivel ENS	Capacidad operativa	Evaluación de madurez (frameworks varios)
6.1 Monitorización OT/ICS	Cobertura de infraestructuras críticas	Art. 21(2),(3)	Sectoriales ENS (energía, etc.)	Infraestructura crítica TIC	ENISA OT, IEC 62443
6.2 Métricas OT	Detección y gestión de incidentes OT	Art. 21(2),(3)	Protección de sistemas ICS	Resiliencia en entornos críticos	ENISA OT, guías sectoriales
6.3 Monitorización 5G	Telecomunicaciones críticas	Art. 21(2),(3)	ENS sector telecom	Infraestructuras críticas	Recomendaciones 5G (ENISA, 3GPP)
7.1 Indicadores de riesgo	Conexión SIEM–riesgo de negocio	Art. 21(2),(3)	Gestión de riesgos ENS	Gestión del riesgo TIC	ISO 27005, marcos de riesgo

7.2 Índice global de madurez	Modelo IGM / madurez SIEM	Art. 21(2),(3)	Declaración de conformidad	Evaluaciones periódicas	Cláusula 9 y 10 ISO 27001
7.3 Uso del SIEM para ROI	Justificación económica de inversiones	Art. 21(2),(3)	Proporcionalidad ENS	Coste/beneficio de controles	Gestión financiera de seguridad
7.4 Participación de riesgo/negocio	Gobernanza y alineamiento con negocio	Art. 20, 21	Organización de la seguridad	Gobierno TIC	A.5.1, A.5.4 roles y responsabilidades
8.1 Compartición con CERT	Colaboración y reporte nacional	Art. 26, 27 (cooperación)	Relaciones con CSIRT	Cooperación con autoridades	ENISA CSIRT frameworks
8.2 Referencias ENISA/NCSI	Benchmarking y comparaciones internacionales	Art. 21(3), 27	Mejora continua	Evaluaciones comparativas	NCSI y buenas prácticas
9.1-9.4 Preguntas abiertas	Lecciones aprendidas y propuestas	Art. 21(3)	Mejora continua ENS	Ciclo de aprendizaje	Cláusula 10 mejora continua

3. Uso práctico del mapeo

- Para cada bloque de análisis, se pueden agrupar las respuestas según los marcos relevantes.
- Las organizaciones pueden utilizar el mapeo para revisar su grado de alineamiento normativo y detectar lagunas específicas (por ejemplo, fuerte foco en operación pero débil conexión con obligaciones de notificación).
- Reguladores y CERT pueden cruzar la información con planes de acción y guías de mejora.

Fin del mapeo.